



RADIUS



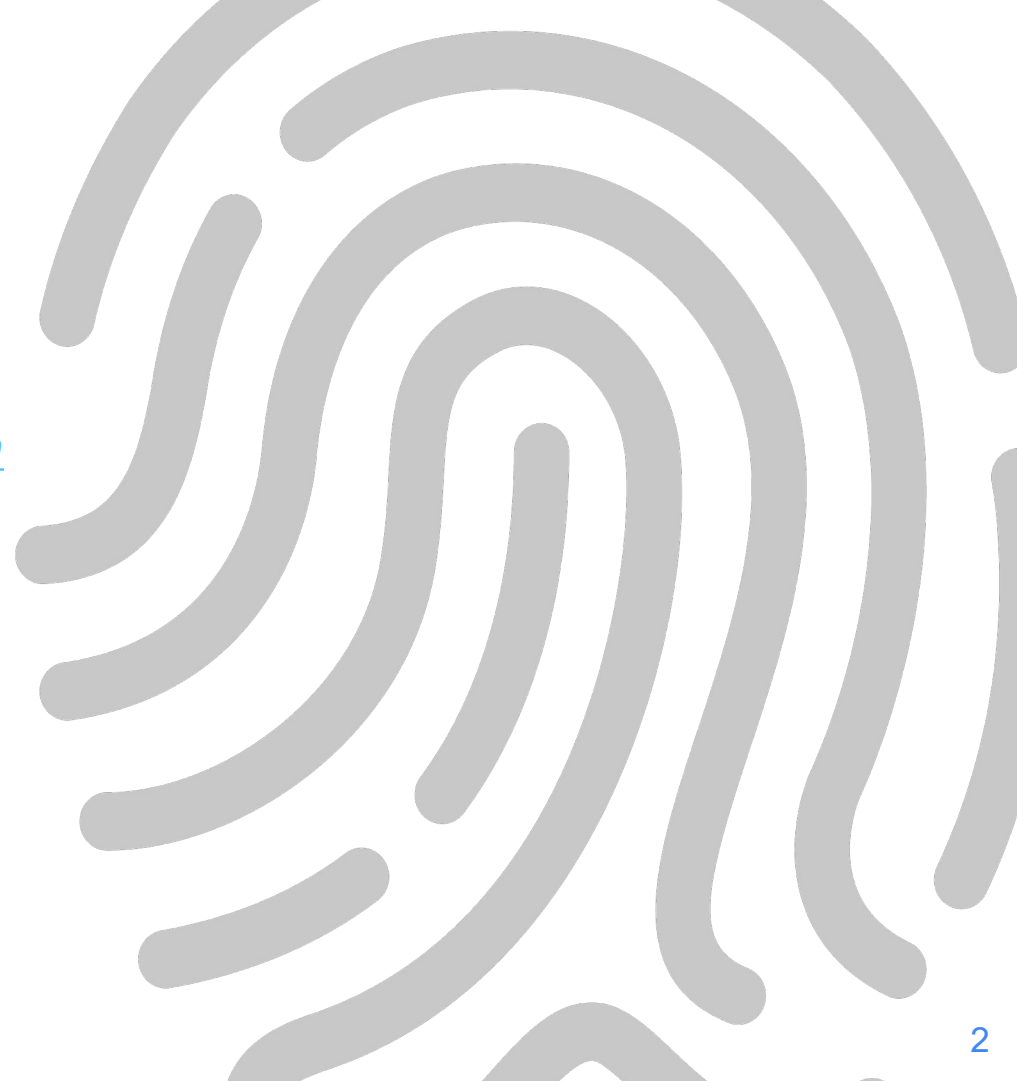
Plan

1 - Le contexte

2 - Le fonctionnement

3 - Les protocoles d'authentification

4 - Traçabilité





Le contexte



RADIUS

Remote Authentication Dial-In User Service

Protocole dit AAA :

- **Authentication** (*Authentification - Vérification d'identité*)
- **Authorization** (*Droits d'accès*)
- **Accounting** (*Traçabilité*)

Développé par la société Livingston (1991)

Standard IETF : RFC [2865](#) et [2866](#)

Port 1812 et 1813 (UDP ou TCP)



Objectifs de RADIUS

Contrôle d'accès à un réseau

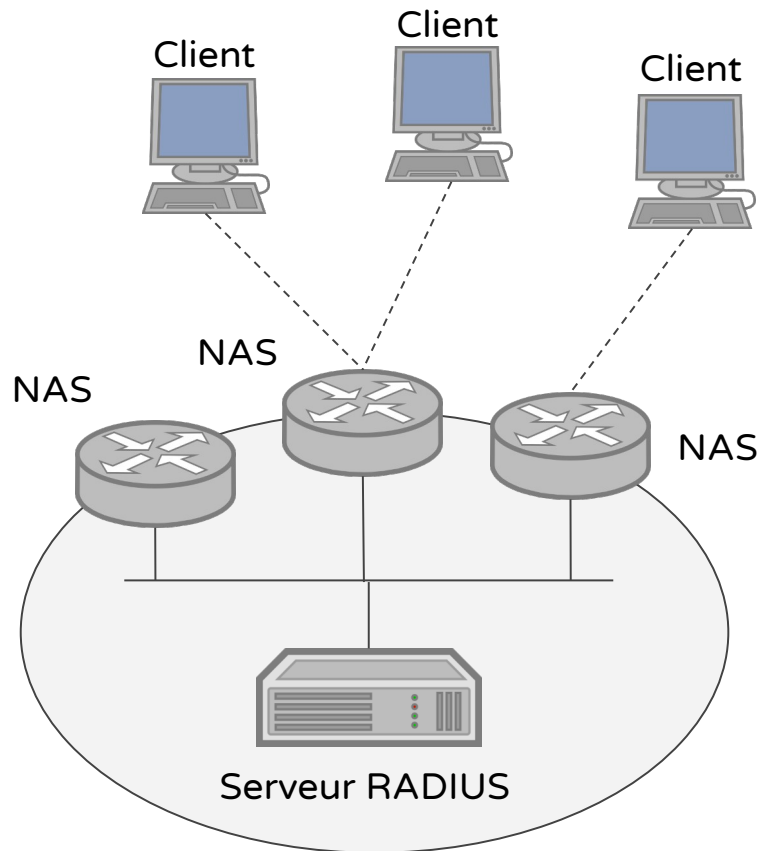
Points d'entrée : Network Access Server

Chaque NAS doit autoriser (ou pas) l'accès à des clients

RADIUS => Centraliser les comptes

Historiquement : accès via modem au réseau d'un FAI

Aujourd'hui : centralisation de l'authentification générique





Les fonctionnalités

Modèle client/serveur

- *Serveur RADIUS*
- *Client RADIUS : des NAS*

Communications sécurisées

- *Authentification des réponses via secret partagé*
- *Chiffrement (uniquement) des mots de passes transmis*

Mécanismes d'authentification flexibles et extensibles



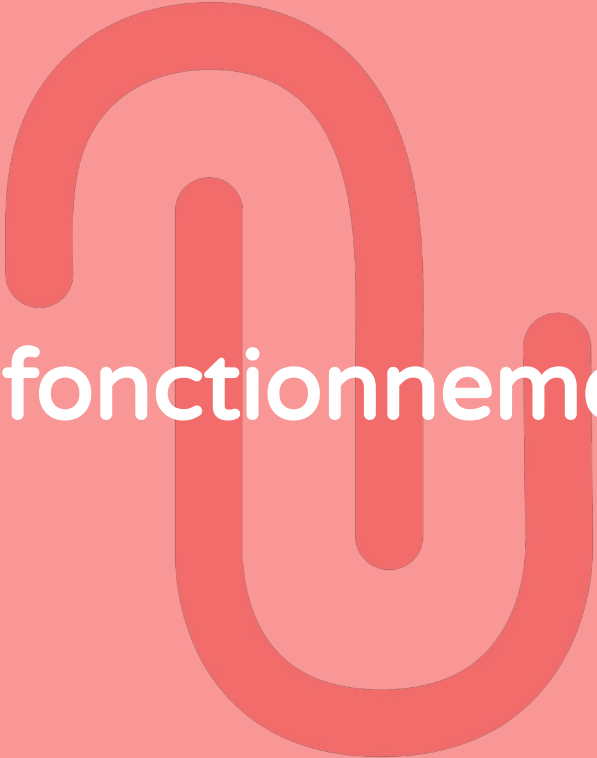
Les implémentations

Serveurs RADIUS :

- [FreeRADIUS](#)
- [Network Policy Server](#) - NPS (Microsoft)
- [Identity Services Engine](#) - ISE (Cisco)

Clients RADIUS :

- *Points d'accès wifi (Mode EBSS)*
- *Serveurs VPN*
- *Commutateurs Ethernet 802.1x*
- *Serveurs Web (Apache)*



Le fonctionnement



Le principe

Un client RADIUS fournit un service (ex. : Accès au réseau - NAS [PPP](#))

- *Il exige des informations d'authentification (Login/MdP, Certificat, etc...)*
- *Il les transmet via RADIUS au Serveur (Message type : Access-Request)*

Le serveur consulte sa base

- *Informations valides : début d'une session (Message type : Access-Accept)*
- *Si invalides : refus (Message type : Access-Reject)*
- *Complément d'authentification (Message type : Access-Challenge)*

Le serveur peut transmettre à un autre (Proxy)

Secret partagé (client et serveur) - Recommandation : 128 bits aléatoires

- *Authentification du client et du serveur*



Le paquet

Code : Type de paquet

Identifiant : détection des paquets dupliqués

Taille : ensemble du paquet RADIUS

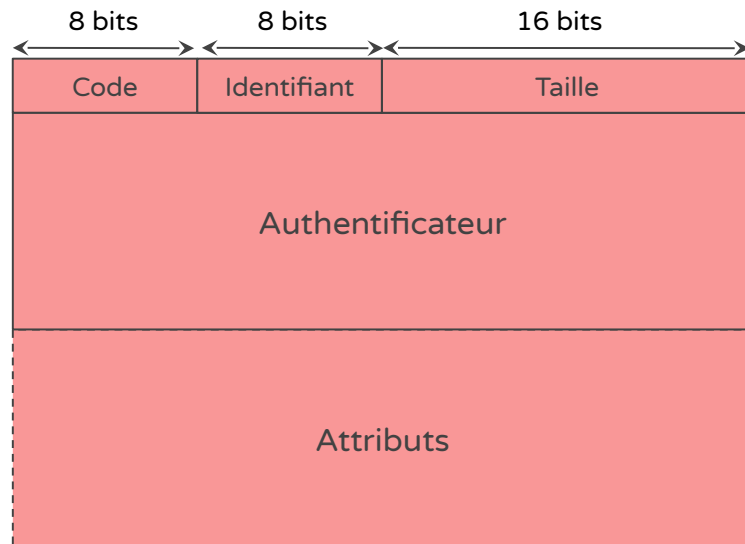
Authentificateur (128 bits) : authentication et protection contre le rejeu

Attributs : Ensemble (variable) d'info nécessaire

Sous la forme : Type - Taille - Valeur

Ex. d'attributs :

User-Name, User-Password, NAS-IP-Address,
NAS-Identifier...





Authenticateur

Lors d'une nouvelle demande (Access-Request)

- *NAS génère un Identifiant unique à la requête*
- *NAS génère une valeur aléatoire (unique et imprévisible) : Authentificateur*
- *Doit contenir un attribut identifiant du NAS (ex. : NAS-Identifier)*

Pour la suite (Access-Accept/Access-Reject/Access-Challenge)

- *Serveur récupère le secret partagé avec ce NAS via son identifiant*
- *L'identifiant de la réponse = celui de la requête*
- *Authentificateur : condensat de Code réponse + Identifiant, taille et authentificateur requête + attributs réponse*



Chiffrement du mot de passe

L'attribut User-Password permet la transmission du mot de passe du client

Ce mot de passe ne circule pas en clair (au contraire de tout le reste)

Chiffrement utilisé (type chiffrement de flux)

- Génération d'une clé de 128 bits
 - via hash (MD5) du secret partagé + authentificateur
- Xor des 16 premiers octets du mot de passe avec cette clé
- Si mot de passe > 16 octets => 2ème tour avec comme clé générée :
 - hash de secret partagé + résultat du premier tour
- etc.

On transmet la concaténation des résultats.



Les protocoles d'authentification



Les mécanismes d'authentification

RADIUS supporte plusieurs mécanismes d'authentification

Historiquement :

- *PAP (Password Authentication Protocol)*
- *CHAP (Challenge Handshake Authentication Protocol)*
- *MS-CHAP (Variante CHAP Microsoft)*
- *EAP (Extensible Authentication Protocol)*



PAP

Password Authentication Protocol :

- *Protocol d'authentification pour [PPP](#) (Point-to-Point Protocol)*
- *Transmission d'un login et d'un mot de passe en clair*
- *Dans RADIUS (entre le NAS et le Serveur) => mot de passe chiffré*

Plus d'info : [PAP sur Wikipédia](#)



CHAP

Challenge Handshake Authentication Protocol :

- *Mécanisme de challenge/réponse*
- *Basé sur la connaissance d'un secret partagé (clé/mot de passe)*
- *Le serveur peut vérifier que le client connaît le secret sans le transmettre*

Principe :

- *Serveur envoi un nombre aléatoire (Access-Challenge)*
- *Le client calcul le condensat de (ce nombre + clé) et renvoi le résultat*
- *Serveur fait le même calcul :*
 - *Si résultats identiques : clé ok / Sinon : échec*

Plus d'info : [CHAP sur WikipediA](#)



MS-CHAP

MicroSoft Challenge Handshake Authentication Protocol :

- Variante Microsoft de CHAP
- MS-CHAPv1 - [RFC 2433](#)
- MS-CHAPv2 - [RFC 2749](#)
- S'appuie sur DES (donc obsolète)

Plus d'info : [MS-CHAP sur WikipediA](#)



EAP

Extensible Authentication Protocol

- *Protocole d'authentification extensible (aussi utilisé avec Wifi)*
- *Multiples mécanismes d'authentification, par exemple :*
 - *EAP-MD5 : Challenge MD5 (Obsolète)*
 - *EAP-POTP : Protected One Time Password*
 - *EAP-PSK : Pre-Shared Key*
 - *EAP-TLS*
 - *EAP-TTLS : Tunneled TLS*
 - *EAP-SIM : Basé sur carte SIM*

Plus d'info : [EAP sur WikipediA](#)



Traçabilité



La traçabilité

RADIUS cible historiquement la gestion de l'accès à distance à un réseau

Typiquement : les fournisseurs d'accès à Internet via modem (RTC)

=> Besoin de décompte de l'utilisation de l'accès

Le 3ème A : Accounting sert à ça :

- Conserver des traces de l'activité*



Gestion de la session

2 types de trafic RADIUS :

- *1812/UDP : Authentification*
- *1813/UDP : Traçabilité*

Types de messages dédiés

- *Accounting-Request*
- *Accounting-Response*

Pour le reste : format de paquet identique



Stockage des informations

2 bases de données distinctes :

- *Base des utilisateurs : information d'authentification et droits d'accès*
- *Base comptable : Information sur l'utilisation des services*

Plusieurs possibilités de stockage :

- *Fichier local*
- *Base de données*
- *Annuaire LDAP*



Considérations supplémentaires

Fonctionnalités additionnelles :

- *Transmission d'information de configuration*
- *Proxy*
- *Redondance de serveurs*

Recommandation de sécurité :

- *Pour communication confidentielle => encapsulation IPsec*

Concurrents :

- *Diameter - [RFC 6733](#)*
- *TACACS+ (Cisco)*



Conclusion

RADIUS protocole simple et efficace

pour authentification centralisée sur un réseau

*Très utilisé pour le contrôle d'accès aux réseaux (Wifi, Ethernet,
Opérateurs ADSL/Fibre)*

Autres mécanismes d'authentification

- Kerberos
- CAS (Central Authentication Service)
- OAuth, OpenID...